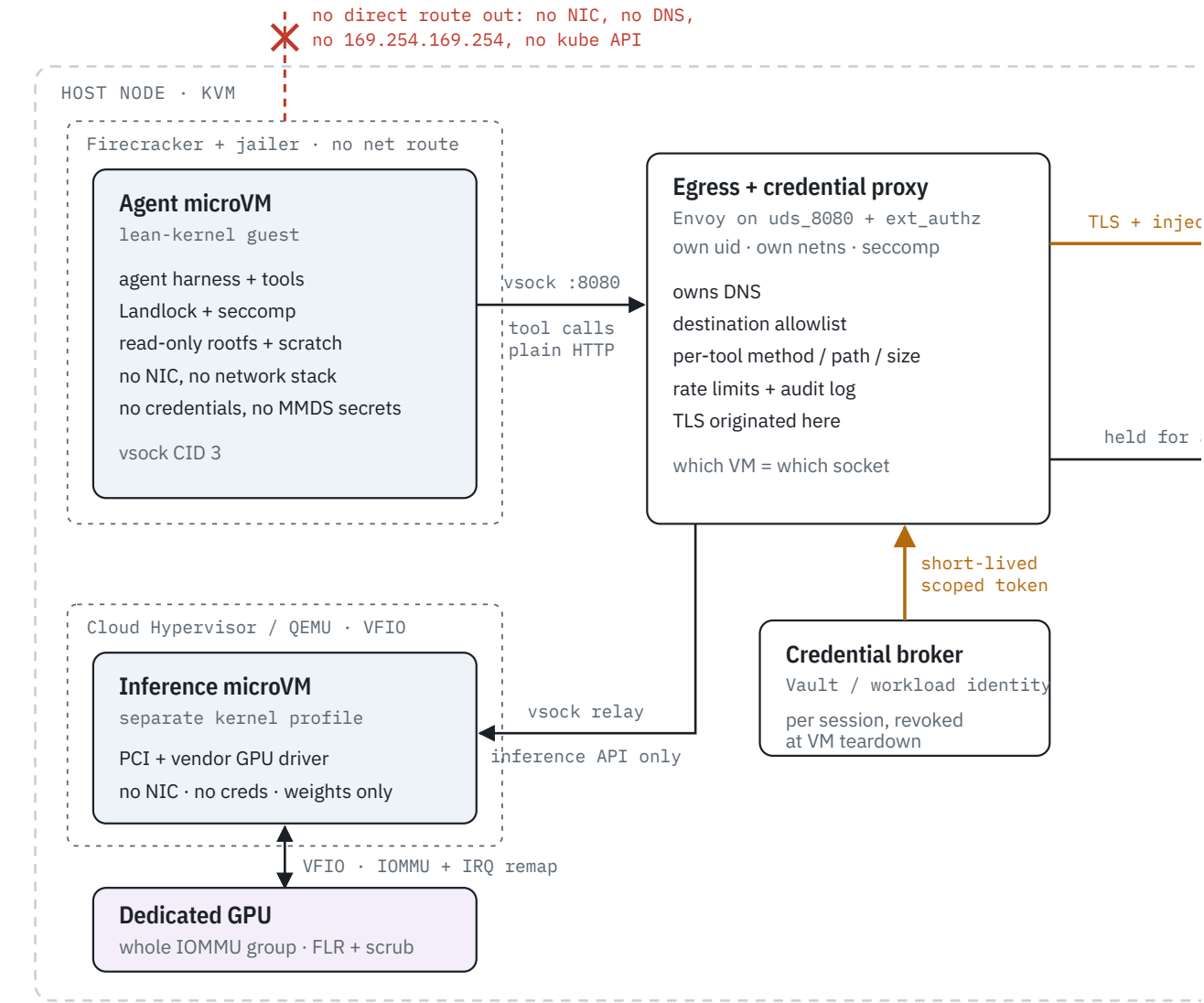
LEAN-KERNEL · DESIGN · 2026-10-30

Agent Sandbox Architecture

An agent with no separate gateway pod. The VM boundary plus one jailed host-side proxy does the gateway's job. The agent guest holds no credentials and has no network. The GPU sits in a separate inference VM.



The agent's only way out is vsock to one host proxy. The proxy knows which VM is calling from the socket the connection arrived on. It adds a short-lived token from the broker, enforces per-tool policy, relays inference calls to the GPU VM, and holds irreversible actions for a human. The GPU never touches the agent's guest.

Boundaries and what each one stops

BOUNDARY	STOPS	DOESN'T STOP
Lean guest kernel	A kernel exploit lands in guest ring 0, not host ring 0. Most 2026 LPE trigger paths (io_uring, user namespaces, BPF) aren't compiled in.	Bugs in what's left; KVM itself.
Firecracker jailer	A VMM escape stays inside a chroot with its own cgroups and seccomp, and no network route.	KVM bugs.
vsock only, no NIC	Direct egress, DNS exfil, the metadata endpoint and the kube API. The guest has no network stack to attack.	Exfil through calls the proxy allows.
Host proxy	Prompt-injected exfil over permitted calls, through per-tool method/path/size rules, rate limits and a full audit log. No CA has to be planted in the guest.	Misuse that fits inside the policy.
Credential broker	Theft. The secret never enters the guest, and tokens are scoped, short-lived and revoked at teardown.	Use of a token's authority through allowed calls.
Inference VM split	PCI, the vendor GPU driver and model weights stay out of the agent's guest. If the GPU VM is compromised, it holds no credentials and has no egress.	GPU firmware persisting across tenants.
Human approval	Irreversible actions taken on injected instructions.	Approval fatigue.

Still open

- A remote model API remains an allowed path out, because prompt content is data. Local inference in the GPU VM closes it.
- Firecracker VFIO passthrough was landing in spring 2026 (PR #5870, `--enable-pci`) but isn't confirmed in a release. Until it is, the inference VM runs on Cloud Hypervisor or QEMU.
- Shared GPU access (vGPU, MIG across tenants, gVisor nvproxy) would expose the host GPU driver to the guest. The design assumes one dedicated GPU per trust domain.
- Nothing here bounds KVM. Host patch cadence still matters.